

TP : Défense Périphérique, Logs et Chiffrement Linux

Objectifs

1. Déployer un pare-feu local (Host-Based Firewall) en mode "Zero Trust".
2. Configurer la centralisation des logs vers un SIEM de manière sécurisée.
3. Créer et manipuler un volume chiffré LUKS (FDE - Full Disk Encryption).
4. Durcir le service de temps (NTP) pour garantir la chronologie légale.

Pare-feu local (Zero Trust avec UFW)

Plutôt que de manipuler les règles complexes de `nftables`, nous allons utiliser l'interface simplifiée **UFW** imposée sur les systèmes Debian/Ubuntu.

1.1 Préparation et politique par défaut

- Assurez-vous qu'UFW est bien installé (il l'est généralement par défaut) :
`sudo apt-get install ufw -y`
 - 1.
- **ATTENTION** : Avant d'activer le pare-feu, il faut absolument autoriser le trafic SSH, sinon vous serez définitivement déconnecté de la machine ! Appliquez une règle intelligente qui limite le taux de connexion (Anti-Brute Force) pour le port SSH :
`sudo ufw limit ssh`
 - 2.
- Définissez la politique stricte de type "Zero Trust" (Tout refuser en entrée, tout autoriser en sortie) :
`sudo ufw default deny incoming`
- `sudo ufw default allow outgoing`
 - 3.

1.2 Activation et journalisation

- Activez le pare-feu (validez avec `y` si le système vous avertit d'une coupure possible) :
`sudo ufw enable`
 - 1.
- Activez le mode de journalisation sur "Moyen" pour tracer les paquets bloqués à des fins d'audit :
`sudo ufw logging medium`

- 2.
- Vérifiez l'état de vos règles :
sudo ufw status verbose
- 3.

Centralisation sécurisée des logs (Rsyslog)

L'ANSSI interdit de conserver les journaux d'audit uniquement en local. Si le serveur est piraté, les logs seront effacés. Nous allons configurer l'envoi de nos logs vers un SOC/SIEM externe (fictif pour ce TP) via le protocole TCP (plus fiable que l'UDP).

- Créez un fichier de configuration dédié à la centralisation :
sudo nano /etc/rsyslog.d/99-siem-externe.conf
- 1.
- Ajoutez la directive suivante pour envoyer TOUS les logs (*) vers l'adresse IP de notre SIEM (ici l'IP fictive 192.168.100.200) sur le port TCP 6514. (Note : Le double @@ force l'utilisation du protocole TCP) :
*. * @@192.168.100.200:6514
- 2.
- Sauvegardez le fichier et relancez le service pour appliquer la modification :
sudo systemctl restart rsyslog
- 3.

Protection de la Donnée (LUKS)

Face à un accès physique ou un vol de Snapshot (VMware), le durcissement OS est inutile. Nous allons créer un coffre-fort cryptographique LUKS (l'équivalent de BitLocker). *Pour éviter d'endommager vos partitions système, nous allons créer un faux disque dur virtuel de 100 Mo.*

3.1 Création et formatage du disque virtuel

- Créez un fichier vide de 100 Mo qui servira de disque :
sudo dd if=/dev/zero of=/tmp/disque_secret.img bs=1M count=100
- 1.
- Formatez ce fichier en partition chiffrée LUKS (Tapez YES en majuscules quand demandé, puis choisissez une phrase secrète robuste) :
sudo cryptsetup luksFormat /tmp/disque_secret.img
- 2.

3.2 Ouverture et utilisation du coffre-fort

- Déverrouillez le disque (vous devrez saisir la phrase secrète). Le disque sera "mappé" (monté virtuellement) sous le nom coffre_ouvert :

```
sudo cryptsetup luksOpen /tmp/disque_secret.img coffre_ouvert
```

1.

- Le disque est maintenant déchiffré mais il est brut. Formatez-le avec un système de fichiers classique (Ext4) :

```
sudo mkfs.ext4 /dev/mapper/coffre_ouvert
```

2.

- Montez-le dans le système pour pouvoir y écrire vos fichiers :

```
sudo mkdir -p /mnt/secret
```

- `sudo mount /dev/mapper/coffre_ouvert /mnt/secret`

3.

- **Validation** : Écrivez un fichier texte à l'intérieur :

```
echo "Base de données clients ultra confidentielle" | sudo tee /mnt/secret/clients.txt
```

4.

3.3 Fermeture (Mise en sécurité)

Une fois l'opération terminée, il faut refermer le coffre.

- Démontez le dossier :

```
sudo umount /mnt/secret
```

1.

- Verrouillez le disque LUKS (la donnée redevient illisible) :

```
sudo cryptsetup luksClose coffre_ouvert
```

2.

Durcissement Temporel (NTP / Chrony)

Le démon **chrony** synchronise l'horloge. Un attaquant peut manipuler le temps pour rendre des certificats TLS valides ou brouiller vos logs.

- Installez le démon NTP moderne :

```
sudo apt-get install chrony -y
```

- Éditez le fichier de configuration :

```
sudo nano /etc/chrony/chrony.conf
```

- À la fin du fichier, ajoutez cette ligne stricte pour interdire à Chrony d'ouvrir un port d'écoute réseau. (*Votre serveur doit être uniquement un client, pas un fournisseur d'heure, ce qui ferme un vecteur d'attaque DDoS*) :

port 0

- Sauvegardez et relancez le service :
`sudo systemctl restart chrony`